



Vulnerability Assessment &
Penetration Testing (VAPT) Report

Ambledown Financial Services (PTY)

30th April 2024



TABLE OF CONTENTS

1	EXECUTIVE SUMMARY	3
2	SCOPE OF TESTING.....	3
3	METHODOLOGIES USED	3
3.1	NMAP / ZENMAP.....	3
3.2	NESSUS	4
3.3	GREENBONE ENTERPRISE	4
4	STAY ONE STEP AHEAD OF ATTACKERS.....	4
4.1	OWASP.....	5
4.2	BRUTE FORCE.....	5
4.3	APPLICATIONS USED IN BRUTE FORCE INCLUDE:	6
5	INFRASTRUCTURE	6
5.1	AFRIHOST SERVER – 154.0.171.224 (AMBLE UAT).....	6
5.2	DATA KEEPERS SERVER – 102.67.139.234 (AMBLE LIVE)	10
5.3	FIREWALL – HEAD OFFICE PORT FORWARDS – 41.169.103.84 (AMBLE FIREWALL).....	12
5.4	ACTIVE DIRECTORY / VPN SERVER – 192.168.0.22	16
5.5	FORTIGATE FIREWALL RULES	17
5.6	WIRELESS NETWORK.....	17
6	REPORTING CONCLUSION	19
7	AUDITORS	19



1 EXECUTIVE SUMMARY

The purpose of this assessment was to point out security loopholes, business logic errors, and missing best security practices. The tests were carried out assuming the identity of an attacker or a malicious user but, no harm was made to the functionality or working of the application / network. A full scan was also performed on the infrastructure to demonstrate a known attack, i.e. someone on the internal network or same public subnetted infrastructure. The scans and brute force were performed over 10 (ten) business days, as full and slow comprehensive audits were performed. These types of scans also look at unknown connectivity options, including packet SYN requests.

The overall results will be published below, High-level, Sautech is comfortable and happy with the results. Some recommendations however, is offered and also mentioned throughout this document.

2 SCOPE OF TESTING

Security assessments include testing for security loopholes in the scope defined below. Apart from the following, no other information was provided. Nothing was assumed at the start of the security assessment. The following scope of servers were covered under the security audit:

- Server hosted at Afrihost (Amble UAT Server) - 154.0.171.224
- Server hosted at DataKeepers (Amble Live Server) – 102.67.139.234
- Firewall at Head Office and associated Port Forwards – 41.169.103.84
- Active Directory Policies
- FortiGate Firewall Rules
- Wireless Network Security

3 METHODOLOGIES USED

Sautech performed various audit techniques that includes the following:

3.1 Nmap / Zenmap

Nmap, short for Network Mapper, is a free and open source tool used for vulnerability checking, port scanning and, of course, network mapping. Despite being created back in 1997, Nmap remains the gold standard against which all other similar tools either commercial or open source, are judged.

To deploy Nmap, users originally had to have some advanced programming skills, with the introduction of the Zenmap tool for Nmap, which adds a graphical interface that makes launching the program and analysing the returned output it generates much more accessible.

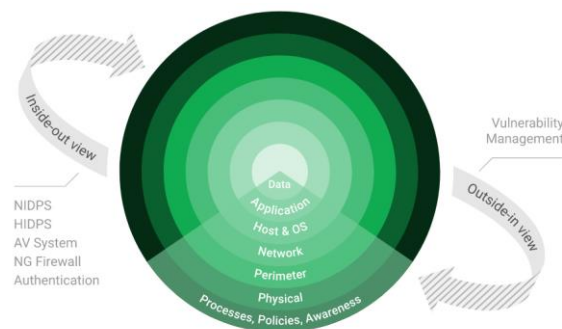


3.2 Nessus

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network. It does this by running over 1200 checks on a given computer, testing to see if any of these attacks could be used to break into the computer or otherwise harm it.

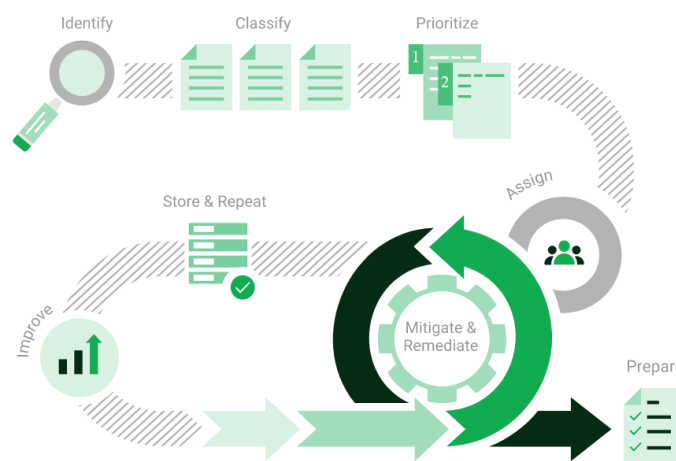
3.3 Greenbone Enterprise

Greenbone is the world's most widely used vulnerability management provider.



4 STAY ONE STEP AHEAD OF ATTACKERS

IT security is a process – Open Source vulnerability management provides the foundation. Once you know where the chinks are in your armor, you can do something about them.

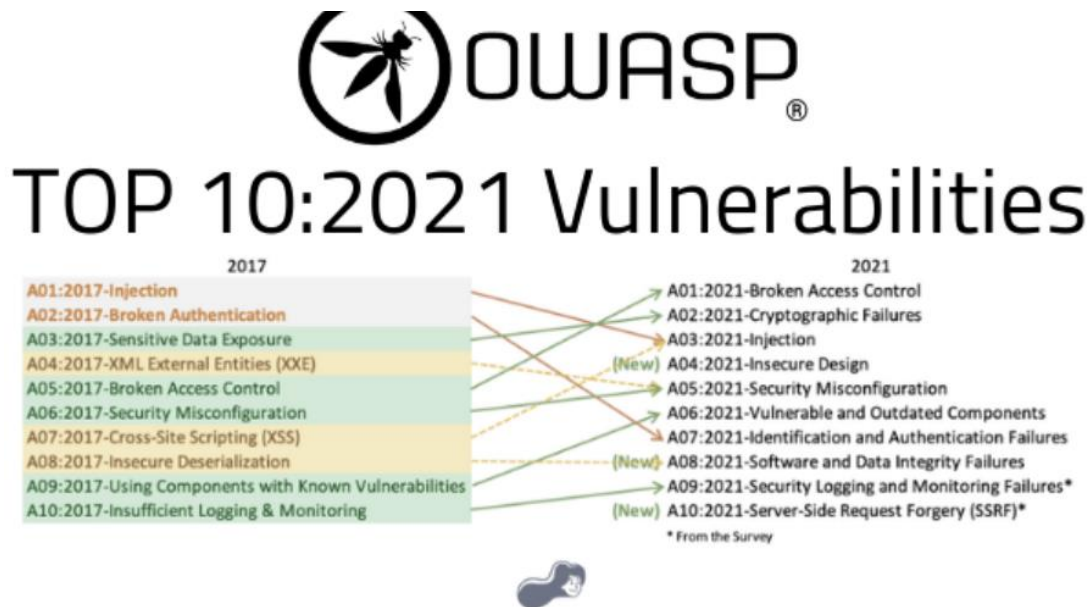


The process – from recognition to remedy and monitoring – represents a continuous cycle. You'll always be one step ahead of attackers.



4.1 OWASP

The Open Web Application Security Project (OWASP) is an online community that produces freely-available articles, methodologies, documentation, tools, and technologies in the field of web application security. The Open Web Application Security Project (OWASP) provides free and open resources. It is led by a non-profit called The OWASP Foundation. The OWASP Top 10 - 2021 is the published result of recent research based on comprehensive data compiled from over 40 partner organizations.



4.2 BRUTE FORCE

- A brute force attack is a hacking method that uses trial and error to crack passwords, login credentials, and encryption keys. It is a simple yet reliable tactic for gaining unauthorized access to individual accounts and organizations' systems and networks. The hacker tries multiple usernames and passwords, often using a computer to test a wide range of combinations, until they find the correct login information.
- The name "brute force" comes from attackers using excessively forceful attempts to gain access to user accounts. Despite being an old cyberattack method, brute force attacks are tried and tested and remain a popular tactic with hackers.



4.3 Applications used in Brute Force Include:

Hydra is a parallelized network login cracker built in various operating systems like Kali Linux, Parrot and other major penetration testing environments. Hydra works by using different approaches to perform brute-force attacks in order to guess the right username and password combination. Hydra is commonly used by penetration testers together with a set of programmes like crunch,[2] cupp[3] etc, which are used to generate wordlists. Hydra is then used to test the attacks using the wordlists that these programmes created.

Over 2.5 Million + Username and password combos are used to Brute force application like RDP, SSH etc.

5 INFRASTRUCTURE

5.1 Afrihost Server – 154.0.171.224 (Amble UAT)

We have performed three types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.
- Brute Force Attacks.

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

Port	Protocol	State	Service	Version
21	tcp	open	ftp	Microsoft ftpd
80	tcp	open	http	Microsoft IIS httpd 8.0
110	tcp	open	pop3	hMailServer pop3d
143	tcp	open	imap	hMailServer imapd
443	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
3306	tcp	open	mysql	MySQL 5.5.5-10.2.6-MariaDB

Remote Operating System Detection:

- Used Port: 21/tsp (open)
- Used Port: 80/tsp (open)
- Used Port: 110/tsp (open)
- Used Port: 143/tsp (open)
- Used Port: 443/tsp (open)
- Used Port: 3306/tsp (open)
- OS match: Microsoft Windows Server 2012 or Windows Server 2012 R2 (89%)



As detected above, Windows 2012 is being used on the server. As per the Microsoft support lifecycle, there is no more support or updates available. It is critical to upgrade to a later version OS as soon as possible.

Should **Port 3306** not be needed over public access, the port ought to be closed. If **Port 3306** is needed over public access, we recommend it only be accessed over VPN or SSL Cert.

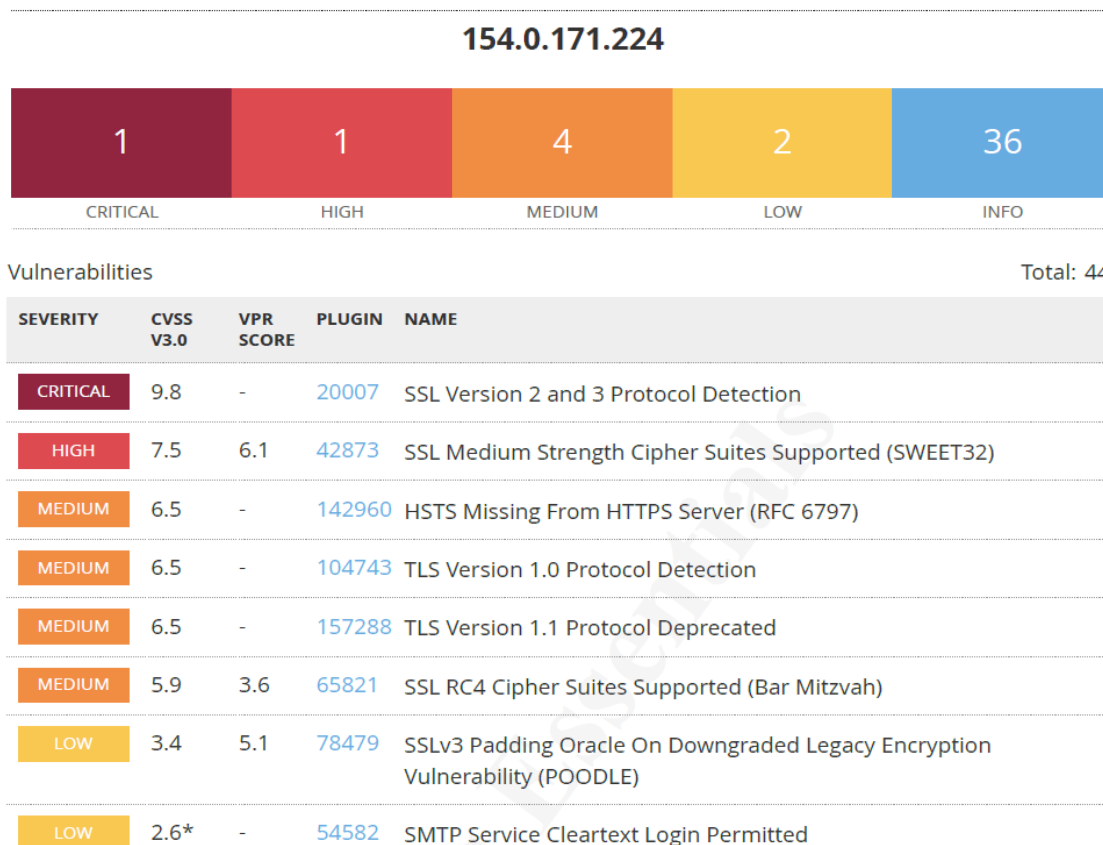
Support Dates

Listing	Start Date	Mainstream End Date	Extended End Date
Windows Server 2012 R2	Nov 25, 2013	Oct 9, 2018	Oct 10, 2023

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.





INFO	N/A	-	46180	Additional DNS Hostnames
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	10092	FTP Server Detection
INFO	N/A	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	12053	Host Fully Qualified Domain Name (FQDN) Resolution
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11414	IMAP Service Banner Retrieval
INFO	N/A	-	10719	MySQL Server Detection
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	50845	OpenSSL Detection
INFO	N/A	-	10185	POP Server Detection
INFO	N/A	-	54580	SMTP Authentication Methods
INFO	N/A	-	10263	SMTP Server Detection
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	83298	SSL Certificate Chain Contains Certificates Expiring Soon
INFO	N/A	-	42981	SSL Certificate Expiry - Future Expiry
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	95631	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites



INFO	N/A	-	22964	Service Detection
INFO	N/A	-	11153	Service Detection (HELP Request)
INFO	N/A	-	14773	Service Detection: 3 ASCII Digit Code Responses
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	11422	Web Server Unconfigured - Default Install Page Present

Should the SMTP Service not be needed over public access, the port ought to be closed. If the SMTP service is be needed over public access, we recommend it only be accessed over VPN or SSL Cert.

iii) Brute Force

Randomised usernames with a word list containing more than 2.5 million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.

```
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

[INFORMATION] reading restore file ./hydra.restore
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2024-04-24 14:15:46
[DATA] max 4 tasks per 1 server, overall 4 tasks, 20469 login tries (l:1/p:20469), ~5118 tries per task
[DATA] attacking ssh://41.76.215.242:22/
[STATUS] 584.00 tries/min, 584 tries in 00:01h, 19885 to do in 00:35h, 4 active
[STATUS] 207.00 tries/min, 621 tries in 00:03h, 19848 to do in 01:36h, 4 active
[STATUS] 100.43 tries/min, 703 tries in 00:07h, 19766 to do in 03:17h, 4 active
[STATUS] 58.67 tries/min, 880 tries in 00:15h, 19589 to do in 05:34h, 4 active
[STATUS] 36.68 tries/min, 1137 tries in 00:31h, 19332 to do in 08:48h, 4 active
[STATUS] 28.34 tries/min, 1332 tries in 00:47h, 19137 to do in 11:16h, 4 active
[STATUS] 24.19 tries/min, 1524 tries in 01:03h, 18945 to do in 13:04h, 4 active
[STATUS] 21.73 tries/min, 1717 tries in 01:19h, 18752 to do in 14:23h, 4 active
[STATUS] 19.37 tries/min, 1840 tries in 01:35h, 18629 to do in 16:02h, 4 active
```

As per the HYDRA screen shot above, all know accounts have been scanned and with no passwords found. We are satisfied with the results.



5.2 Data Keepers Server – 102.67.139.234 (Amble Live)

We have performed two types of scans/attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter but also include local network.
- Vulnerability assessments

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

Port	Protocol	State	Service	Version
80	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
443	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
3306	tcp	open	mysql	MySQL 5.5.5-10.4.8-MariaDB
3389	tcp	open	ms-wbt-server	Microsoft Terminal Services

Remote Operating System Detection:

- Used Port: 80/tcp (open)
- Used Port: 443/tcp (open)
- Used Port: 3306/tcp (open)
- Used Port: 3389/tcp (open)

We Recommend closing RDP (3389) or either of the following perform RDP is accessed:

- VPN with Certificate (not username and password combination)
- Configure Local Firewall to only accept RDP connections from known source address
- Install 2FA i.e. Google Authenticator.

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.



102.67.139.234



Vulnerabilities

Total: 31

SEVERITY	CVSS V3.0	VPR SCORE	PLUGIN	NAME
HIGH	7.5	6.1	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
MEDIUM	6.5	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	157288	TLS Version 1.1 Protocol Deprecated
MEDIUM	4.0	-	58453	Terminal Services Doesn't Use Network Level Authentication (NLA) Only
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	10719	MySQL Server Detection
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	66173	RDP Screenshot
INFO	N/A	-	10940	Remote Desktop Protocol Service Detection
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	21643	SSL Cipher Suites Supported



INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	11153	Service Detection (HELP Request)
INFO	N/A	-	84821	TLS ALPN Supported Protocol Enumeration
INFO	N/A	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	64814	Terminal Services Use SSL/TLS
INFO	N/A	-	10287	Traceroute Information

5.3 Firewall – Head Office Port Forwards – 41.169.103.84 (Amble Firewall)

We have performed three types of scans / attacks on the production server namely:

- Port Mapping (Open / Exposed Services) These were performed from unknown and known locations to test not just the security from the perimeter, but also include local network. Based on the port mapping open access to Public and Private, selected coordinated assessments were performed specific to the open connectivity received.
- Vulnerability Assessments.
- Brute Force Attacks.

i) Port Mapping

Nmap can be used by hackers **to gain access to uncontrolled ports on a system**. All a hacker would need to do to successfully get into a targeted system would be to run Nmap on that system, look for vulnerabilities, and figure out how to exploit them.

The below screenshot demonstrates the open network port mapping:

Port	Protocol	State	Service	Version
21	tcp	open	ftp	FileZilla ftpd 0.9.34 beta
22	tcp	open	ssh	Bitvise WinSSHD 9.32 (FlowSsh 9.32; protocol 2.0)
80	tcp	open	http	Microsoft IIS httpd 8.5
443	tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
445	tcp	open	microsoft-ds	Microsoft Windows Server 2008 R2 - 2012 microsoft-ds
1723	tcp	open	pptp	
8008	tcp	open	http	Apache httpd 2.4.41 ((Ubuntu) mod_wsgi/4.6.8 Python/3.8)
113	tcp	closed	ident	
990	tcp	closed	ftps	



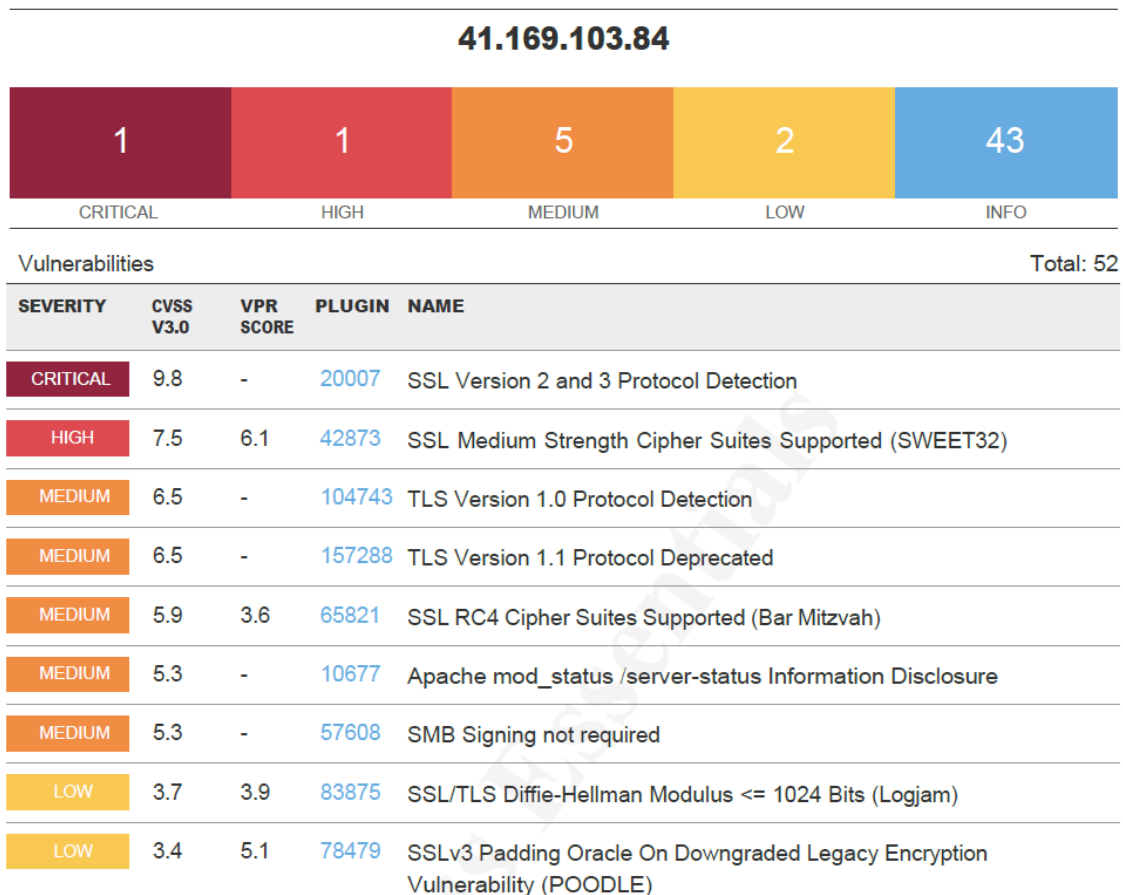
Remote Operating System Detection:

- Used Port: 21/tsp (open)
- Used Port: 22/tsp (open)
- Used Port: 80/tsp (open)
- Used Port: 443/tsp (open)
- Used Port: 445/tsp (open)
- Used Port: 1723/tsp (open)
- Used Port: 8008/tsp (open)
- Used Port: 113/tsp (closed)
- Used Port: 990/tsp (closed)

ii) Vulnerability Assessment

Multiple technologies were used to perform a vulnerability assessment, below is the summarised version of the relevant results:

We have attached the below “highlight” in a separate report so that you can click on the “Plugin” link to get the resolution.





INFO	N/A	-	48204	Apache HTTP Server Version
INFO	N/A	-	39521	Backported Security Patch Detection (WWW)
INFO	N/A	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	54615	Device Type
INFO	N/A	-	10092	FTP Server Detection
INFO	N/A	-	84502	HSTS Missing From HTTPS Server
INFO	N/A	-	43111	HTTP Methods Allowed (per directory)
INFO	N/A	-	10107	HTTP Server Type and Version
INFO	N/A	-	24260	HyperText Transfer Protocol (HTTP) Information
INFO	N/A	-	11935	IPSEC Internet Key Exchange (IKE) Version 1 Detection
INFO	N/A	-	11387	L2TP Network Server Detection
INFO	N/A	-	42410	Microsoft Windows NTLMSSP Authentication Request Remote Network Name Disclosure
INFO	N/A	-	10785	Microsoft Windows SMB NativeLanManager Remote System Information Disclosure
INFO	N/A	-	11011	Microsoft Windows SMB Service Detection
INFO	N/A	-	100871	Microsoft Windows SMB Versions Supported (remote check)
INFO	N/A	-	106716	Microsoft Windows SMB2 and SMB3 Dialects Supported (remote check)
INFO	N/A	-	11219	Nessus SYN scanner
INFO	N/A	-	19506	Nessus Scan Information
INFO	N/A	-	11936	OS Identification
INFO	N/A	-	117886	OS Security Patch Assessment Not Available
INFO	N/A	-	50845	OpenSSL Detection
INFO	N/A	-	10622	PPTP Detection
INFO	N/A	-	122364	Python Remote HTTP Detection
INFO	N/A	-	31422	Reverse NAT/Intercepting Proxy Detection
INFO	N/A	-	56984	SSL / TLS Versions Supported
INFO	N/A	-	45410	SSL Certificate 'commonName' Mismatch



INFO	N/A	-	10863	SSL Certificate Information
INFO	N/A	-	95631	SSL Certificate Signed Using Weak Hashing Algorithm (Known CA)
INFO	N/A	-	70544	SSL Cipher Block Chaining Cipher Suites Supported
INFO	N/A	-	21643	SSL Cipher Suites Supported
INFO	N/A	-	57041	SSL Perfect Forward Secrecy Cipher Suites Supported
INFO	N/A	-	94761	SSL Root Certification Authority Certificate Information
INFO	N/A	-	156899	SSL/TLS Recommended Cipher Suites
INFO	N/A	-	96982	Server Message Block (SMB) Protocol Version 1 Enabled (unauthenticated check)
INFO	N/A	-	22964	Service Detection
INFO	N/A	-	25220	TCP/IP Timestamps Supported
INFO	N/A	-	121010	TLS Version 1.1 Protocol Detection
INFO	N/A	-	136318	TLS Version 1.2 Protocol Detection
INFO	N/A	-	110723	Target Credential Status by Authentication Protocol - No Credentials Provided
INFO	N/A	-	10287	Traceroute Information
INFO	N/A	-	11154	Unknown Service Detection: Banner Retrieval
INFO	N/A	-	135860	WMI Not Available
INFO	N/A	-	10150	Windows NetBIOS / SMB Remote Host Information Disclosure

iii) Brute Force

Randomised usernames with a word list containing more than 2.5 million words and common passwords were brute forced SSH's onto the server using Hydra.

Hydra works by **using different approaches to perform brute-force attacks in order to guess the right username and password combination**. Hydra is commonly used by penetration testers together with a set of programmes like crunch, cupp etc, which are used to generate wordlists.



```
(root@kali)~[/usr/share/wordlists/dirb]
# cat /usr/share/wordlists/dirb/big.txt | thc-pptp-bruter -u admin 41.169.103.84
PPTP Connection established.
Hostname '', Vendor 'Microsoft', Firmware: 0
5 passwords tested in 0h 00m 00s (5.00 5.00 c/s)
200 passwords tested in 0h 00m 05s (39.00 40.00 c/s)
392 passwords tested in 0h 00m 10s (38.40 39.20 c/s)
581 passwords tested in 0h 00m 15s (37.80 38.73 c/s)
771 passwords tested in 0h 00m 20s (38.00 38.55 c/s)
959 passwords tested in 0h 00m 25s (37.60 38.36 c/s)
1147 passwords tested in 0h 00m 30s (37.60 38.23 c/s)
1337 passwords tested in 0h 00m 35s (38.00 38.20 c/s)
1525 passwords tested in 0h 00m 40s (37.60 38.12 c/s)
1715 passwords tested in 0h 00m 45s (38.00 38.11 c/s)
1908 passwords tested in 0h 00m 50s (38.60 38.16 c/s)
2097 passwords tested in 0h 00m 55s (37.80 38.13 c/s)
2285 passwords tested in 0h 01m 00s (37.60 38.08 c/s)
2472 passwords tested in 0h 01m 05s (37.40 38.03 c/s)
2665 passwords tested in 0h 01m 10s (38.60 38.07 c/s)
2855 passwords tested in 0h 01m 15s (38.00 38.07 c/s)
3045 passwords tested in 0h 01m 20s (38.00 38.06 c/s)
```

As per the HYDRA screen shot above, all known accounts have been scanned and with no passwords found. We are satisfied with the results.

5.4 Active Directory / VPN Server – 192.168.0.22

The Active Directory analysis was performed onsite with our team and a couple of items to note below:

1. Password Policies:

- a) Complexity and known passwords we are comfortable with, we will however recommend extending the password length from 8 to 14 characters
- b) **Windows Server 2008 is used and there is no more support or updates to this software, upgrade to newer version as a matter of urgency.**
- c) Local firewall is disabled, enable and only allow services that is needed
- d) No Anti-Virus was detected or installed on the AD Server – Critical
- e) Consider changing the VPN from user/pass based authentication to user/cert-based authentication

Based on the previous reports dated June 2022, it was noticed that multiple recommendations were not implemented. We highly advise applying the relevant changes regarding the above.



2. Domain Policies:

Account Policies/Password Policy	
Policy	Setting
Enforce password history	24 passwords remembered
Maximum password age	42 days
Minimum password age	0 days
Minimum password length	8 characters
Password must meet complexity requirements	Enabled
Store passwords using reversible encryption	Disabled
Account Policies/Account Lockout Policy	
Policy	Setting
Account lockout duration	0 minutes
Account lockout threshold	3 invalid logon attempts
Reset account lockout counter after	99999 minutes
Account Policies/Kerberos Policy	
Policy	Setting
Enforce user logon restrictions	Enabled
Maximum lifetime for service ticket	600 minutes
Maximum lifetime for user ticket	10 hours
Maximum lifetime for user ticket renewal	7 days
Maximum tolerance for computer clock synchronization	5 minutes
Local Policies/Audit Policy	
Policy	Setting
Audit account logon events	Success, Failure
Audit logon events	Success, Failure

As per the above screenshot and with the information disclosed, we are satisfied with the results, however, we do recommend extending the minimum password length from 8 characters to 14 characters.

5.5 FortiGate Firewall Rules

For Security reasons, we will not paste the firewall rules here, this can be obtained manually if need be.

We have only analysed the inbound rules as was the mandate and did not evaluate outbound, IPS or user policies. When we tried to login to the firewall, we were happy to note that entering the wrong password three times. We are also happy to know that the Web UI interface is not accessible via browser externally.

We cannot comment on rules created and why it's needed or not, but we do note there might be some rules that is old/outdated/not needed anymore. Although they pose no direct risk, we would disable/delete what is not needed.

On the rest of the firewall configuration, we are comfortable.

5.6 Wireless Network

We performed a wireless network scan/attack from Kali Linux.

The SSID should be hidden as its easy identifiable by name to which company it belongs and we could then detect easily what Encryption was used. Based on the encryption we knew the amount of characters that will be maximum and scanned the wireless network password.



Please consider changing the password to more Upper/lower/numeric/Symbolic Combinations. Also, please consider when the SSID is hidden, to install a guest WIFI off the main network, separate Vlan with breakout.

1. Available Wireless SSID's:

NUM	ESSID	CH	ENCR	PWR	WPS	CLIENT
1	(6C:CD:D6:5F:57:C1)	5	WPA	99db	no	1
2	ZTE_6832ED	6	WPA-P	44db	no	
3	HUAWEI-5A30	12	WPA-P	43db	yes	
4	Galaxy A13 451E	6	WPA-P	35db	no	1
5	ZTE_6797F1	6	WPA-P	34db	no	
6	E5783_E5A8	5	WPA-P	34db	yes	
7	WAX218B19FB9-CONFIG-ONLY	8	WPA-P	32db	no	
8	Amb_Office_WiFi*	8	WPA-P	32db	no	5
9	Galaxy A30s4E17	6	WPA-P	30db	no	
10	DIRECT-ARDESKTOP-4TFM ...	11	WPA-P	27db	yes	
11	WAX218B19FBC-CONFIG-ONLY	11	WPA-P	26db	no	
12	DIRECT-ARDESKTOP-4TFM ...	11	WPA-P	27db	yes	
13	V6-MIFI-918C	1	WPA-P	26db	no	
14	ZTE_6832F2	11	WPA-P	26db	no	
15	Abbey Telkom	6	WPA-P	24db	yes	
16	Amb_Office_WiFi	11	WPA-P	23db	no	5
17	VodafoneMobileWiFi-07 ...	1	WPA-P	23db	no	
18	ZTE_6D2B14_2.4G	11	WPA-P	18db	yes	

2. Wireless Password Brute Force Attack:

```
[+] analysis of captured handshake file:
[+] tshark: .cap file contains a valid handshake for (94:a6:7e:b1:9f:bd)
[+] aircrack: .cap file contains a valid handshake for (94:A6:7E:B1:9F:BD)

[+] Cracking WPA Handshake: Running aircrack-ng with wordlist-probable.txt wordlist
[+] Cracking WPA Handshake: 0.00% ETA: 11m18s @ 300.4kps (current key: )
[+] Cracked WPA Handshake PSK: 3ns3rv1c3swifi

[+] Access Point Name: Amb_Office_WiFi
[+] Access Point BSSID: 94:A6:7E:B1:9F:BD
[+] Encryption: WPA
[+] Handshake File: hs/handshake_AmbOfficeWiFi_94-A6-7E-B1-9F-BD_2024-04-17T07-57-25.cap
[+] PSK (password): 3ns3rv1c3swifi
[+] saved crack result to cracked.json (1 total)
[+] Finished attacking 1 target(s), exiting
```

Based on the previous reports dated June 2022, it was noticed that the Wireless Key has still not been changed and the Wireless SSID has still not been hidden. We highly recommend applying the relevant changes regarding the above.



6 REPORTING CONCLUSION

Based on the OWASP reports it is best to attach these separate to the reporting document. These reports can then be shared with the relevant contractors and/or support personnel to implement the changes and updates.

It is our view that from External Testing where the SSH port are not open to public, these vulnerabilities then become academic. However, we still recommend that the changes be implemented. Ambledown Financial Services is behind the managed FortiGate firewall.

The HTTPS updates as these are open to the public, low and medium risk, should be tested and implemented as soon as possible.

From a Hosted Infrastructure point of view, we are happy with the results. We do recommend that SenitnelOne is implemented into the production environment as soon as possible. We also recommend where Operating systems are end of life or close to, they be upgraded.

As stated, based on the previous reports dated June 2022, multiple recommendations and changes were not implemented. We highly advise applying same as soon as possible.

Ten addendum reports are attached to this report and should be read as one document.

With the following test performed:

- Network scanning
- IDS/IPS disabled
- Knows network attack (from Internet to the FW)
- External HTTP and Port exploits
- Vulnerability assessment on CVE
- Penetration testing on login ports i.e.: ssh open

7 AUDITORS

These audits were concluded over a period of 10 (ten) business days.
We hereby confirm that the above information is true and correct:

30th April 2024 – Krugersdorp, South Africa

Riaan van Jaarsveld
Security Expert – CCSA / Certified Pen Tester

Lukas Janse van Rensburg
Security Engineer